SCC.443: Forensic Report

April 20, 2026

Terry's Digital Breach Analysis

Contents

1 Introduction **3**
1.1 Investigation timeline . . . 3
1.2 Used tools . . . 3
1.3 Procedures . . . 4

2 Non-Technical Summary **4**

3 Technical Analysis **5**
3.1 Reconnaissance . . . 5
3.2 Analysis . . . 6
3.2.1 Wes Clickwell - 10.10.80.114 - 02:41:54:4c:41:53 - ATLAS: . . . 6
3.2.2 Kerry Cache - 10.10.50.88 - 02:48:59:44:52:41 - HYDRA: . . . 10
3.2.3 Bob Browsalot - 10.10.30.212 - 02:4f:52:49:4f:4e - ORION: . . . 12

4 Results and Conclusion **13**

5 Expert Opinion: Legal Analysis **15**

A CLI commands and hashes **16**

1 Introduction

Terry's Digital, a British confectionery brand, recently was victim of a cyber attack and suffered a data breach. Sensitive client data, such as PII and PCI, might have been leaked on a dark web forum. The data was available only on a critical server accessible only to selected security staff. Mr. Justin Case (CISO), was aware of the recent surge of cyberattacks on the company's infrastructure and staff. He reported the problem to board members but was ignored. Ms. Polly Packet, the Security Manager, provided to ACME-Forensics critical evidence, such as a packet capture of an event window, and relevant data to perform a comprehensive forensic investigation.
This report contains the analysis of those artifacts, including the procedures with their respective timestamps and specifications. The investigation began from the e-mail exchange between the employees, with the subsequent packet analysis using Wireshark, cross-referencing the found data to understand the events timeline.
The following sections provide: the **timeline** of the investigation (1.1), a list of the used **tools** (1.2), the **procedures** mentioned in the timeline with some additional details (1.3), a **summary** of the investigation for an easy comprehension (2), an in-depth **technical** explanation of key findings (3) and at the end a recap of the results of the investigation alongside the **conclusions** (4). Following there is a section dedicated to an **expert opinion** (5), that provides a point of view on the legal aspects of the gathered information. At the bottom of the document there is the **appendix** (A) which contains specific code snippets and additional details related to the technical aspect.

1.1 Investigation timeline

1. File gathering from portal - *20/03/2026 - 10:39:29 AM (UTC)*
2. Exec file run on VDI Barrow (chmod +x on Exec file) - *20/03/2026 - 10:54:42 AM (UTC)* - password input, file generation, 3e547-CAPTURE.pcap and 3e547-KEYS.log
3. Files hash and copy for backup - *30/03/26 - 9:11:24 AM (UTC+1:00/BST)*
4. Initial artifacts hashing - *31/03/26 - 8:00:41 AM (UTC+1:00/BST)*
5. Following the instruction provided in the files *01/04/26 - 8:10:50 AM (UTC+1:00/BST)*
6. In-depth captured network packets analysis - *01/04/26 - 8:25:41 AM (UTC+1:00/BST)*
7. TCP (HTTP/HTTP2/TLS) and UDP streams (including DNS queries) individually analysed, new artifacts creation and subsequent hashing - *started 02/04/26 - 08:39:50 AM (UTC+1:00/BST), finished 17/04/26 - 11:35:46 AM (UTC+1:00/BST)*
8. Logic-chronological facts sorting - *04/04/26 - 9:00:35 AM (UTC+1:00/BST)*
9. Data aggregation - *08/04/26 - 10:02:36 AM (UTC+1:00/BST)*

1.2 Used tools

- cat tool (concatenate)
- Document Viewer (Ubuntu native)
- Text Editor (Ubuntu native)
- md5sum (hashing tool)
- Wireshark (4.2.2 - GitV4.2.2 packaged as 4.2.2-1.1build3)

- Cyberchef v10.22.1
- docker 28.4.0 (downloaded from snap store on Ubuntu CLI), Cyberchef local instance, pulled from docker repository, hosted on 0.0.0.0:8080

1.3 Procedures

1. **E-mail exchange analysis with text view:** it provided initial context on network issues and unusual behaviour from employees;
2. **Host identification:** cross-referencing the e-mails, the employee names provided in them, the data of specific patterns, two host tables have been produced, one is about the internal hosts on the network as requested from Terry's Digital (see tab. 1), the other is a comprehensive table about the end-points involved in suspicious traffic (see tab. 2)
3. **Wireshark packet analysis:** manual iteration between TCP, TLS, UDP, HTTP(2/3) and DNS streams with the aim of catching unusual patterns or malicious traffic;
4. **Evidence extraction:** CyberChef has been used to decode specific content. VirusTotal has been used to check if specific IP addresses or domains were already reported on cybercrime databases.
5. **Evidence collection and hashing:** Any relevant packet stream or data found in the network packet capture has been saved separately. Following, they have been hashed in a separate checksum file with md5sum.

2 Non-Technical Summary

In this section, the findings of the investigation illustrated in the following part, will be explained avoiding too much technical jargon.

The e-mails: After reading the artifacts provided by the Security Manager, Polly Packet, it was clear that something was not working well anymore since Derek D. Dos was complaining about network issues. The Security Manager provided a network capture file that was the main subject of the investigation.

Wes (3.2.1): After confirming what his IP was 10.10.80.114 (see tab. 1) the main traffic he produced was: (i) when he scanned the internal network with ZAP and SSLyze, (ii) when he uploaded the reports on Terry's Digital server, (iii) when he navigated to offensive security tools, (iv) when he navigated Terry's Digital website before and after the encryption of the data and (v) when he registered on a dating website, using the same credentials that he uses to access the company's website.

Kerry (3.2.2): She was confirmed to be AWOL (by B. Browsalot, on the email) the night of the data leakage. The suspicious activities she was caught doing from the traffic capture were: (i) when she connected to dark web page, (ii) when she had a chat with someone called MYST3RION, in order to buy a "dump", (iii) when she paid in a strange currency (as-co.in) to buy this dump, apparently related to a *chocolate company*, (iv) when she downloaded it, but actually it was a keylogger and (v) when she installed it and sent keystrokes as DNS queries to the threat actor hosting the service to log what she was typing.

Bob (3.2.3): From the network packet capture, it could be seen that he was: (i) venting to ChatGPT about his frustration for his job, (ii) was asking to ChatGPT how to leverage sensitive data to earn money from the company, since he had access to it, (iii) then he changed idea and asked the chatbot how to leave his company selling his cryptocurrency and settle at the Maldives. Finally, (iv) he registered to a Maldives travelling website.

3 Technical Analysis

First of all the files subject of investigation were downloaded from the Moodle portal. From the recovered artifacts, on Tuesday, 11 March 2025 at 02:17:47 AM (UTC), Derek D. Dos (**D**) reported to his colleagues through an e-mail (to b.browsalot@terrys-digital.uk (**B**) and w.clickwell@terrys-digital.uk (**W**)) that he was experiencing networking issues and couldn't authenticate to <REDACTED>.
B answered to **D** that the network issue was *typical* at that time of the day and that the person to who he usually reports this kind of problems (K. Cache (**K**)) was not available at that time (AWOL). This e-mail was sent on Tuesday, 11 March 2025, at 02:18:05 AM (UTC).
B then proceeded to inform **W** that the network issue reported by **D** was irrelevant. He then asks about news on SLAs for McVities because **W** had been silent for a while. This e-mail was sent on Tuesday, 11 Mar 2025 02:19:16 AM (UTC).
This message exchange gives context on the fact that **K** and **W** were not available at that time, even though the tone of **B** suggest that usually they are online.
The e-mails were accessed on the 31st of March 2026, between 8:15 AM and 8:37 AM (UTC+1:00/BST). The hashes of the artifacts were checked before and after accessing the files.
The instructions suggested to run the "Exec" file on the machine. Once that was done two files were the output: 3e547-CAPTURE.pcap and 3e547-KEYS.log. Next they were copied for backup and hashed.

3.1 Reconnaissance

To analyse the captured packets the 3e547-CAPTURE.pcap the file was opened through Wireshark.
Analysing the capture timeframe it could be noticed that the capture began the 11th of March 2025 at 02:00:32 AM (UTC) and ended the 11th of March 2025 at 02:16:14 AM (UTC). On Wireshark, go to Statistics → Capture File Properties or press Ctrl+Alt+Shift+C,
Total capture elapsed time 00:15:41.
The time-span in which the aforementioned communication happened relates to this since the first e-mail was sent at 02:17:47 AM (UTC) from **D**.
During this phase all 969 TCP streams have been manually and individually searched for information related to the data breach. (Including TCP, HTTP/HTT2/HTTP3).
From the analysis a table of the main hosts has been reconstructed, cross-referencing information from the e-mails, brief and captured packets. The following table provides the main information on the employees and internal server (nginx).
The hostnames were appearing in the captured packets. The last 5 bytes of the internal host MAC addresses encoded the ASCII format of their name, e.g. 02:4f:52:49:4f:4e → 0x4F 0x52 0x49 0x4F 0x4E = O R I O N, same for HYDRA and ATLAS.

IP Address	MAC Address	Hostname	Employee Name	Role	Email
10.10.0.1	0a:00:27:00:00:0a	Server	N/A	Internal File/Web Server	N/A
10.10.30.212	02:4f:52:49:4f:4e	ORION	Bob (Browsalot)	Security Analyst	b.browsalot@terrys-digital.uk || bob@terrys-digital.uk
10.10.50.88	02:48:59:44:52:41	HYDRA	Kerry Cache	Security Analyst	k.kache@terrys-digital.uk
10.10.80.114	02:41:54:4c:41:53	ATLAS	Wes Clickwell	Security Analyst	wes-clickwell@terrys-digital.uk

Table 1: Hosts and Employees

3.2 Analysis

In order to extract the most information out of the packets capture several protocol streams have been checked manually, given that the Security Manager provided the keys to follow encrypted communications as well (151 TLS streams). The collected evidence will be listed based on the internal hosts. After collecting and organizing the evidence in a dedicated folder (Evidence), the content has been hashed (see appendix A).

3.2.1 Wes Clickwell - 10.10.80.114 - 02:41:54:4c:41:53 - ATLAS:

1. The first finding was in the **44th TCP stream** (see **Evidence/Atlas_Wes_1 - TCP + HTTP Stream 44.pcapng**), where it could be seen that on the 11th of March 2025, at 02:01:21 AM (UTC), Wes Clickwell (Atlas) accessed the critical server. His credentials could also be retrieved from the 4th frame of the overall capture, within the HTTP GET request to the 10.10.0.1 server: the authentication token contained a Basic base64 encoding of his credentials, easily retrievable through a base64 converter. Cyberchef has been used to do this, the encoded credentials were:

   d2VzLWNsaWNrd2VsbDpnaG9zdGludGhlc2hlbGw=

   It translates to: **wes-clickwell:ghostintheshell**.

2. From the generated traffic it could be deduced that he was navigating though Terry's Digital website, in fact the following finding is in the **64th TCP** stream, in which Wes navigates to the projects, sending another HTTP GET request. It can be seen from the authentication token that it is still him because it is the same as the previous call (see **Evidence/Atlas_Wes_2 - TCP + HTTP Stream 64.pcapng**). 19 seconds later the previous call, at 02:01:40 AM (UTC), Wes went into the PROJECTS folder. Next, 8 seconds later, Wes downloaded the picture of the company's headquarters, at 02:01:48 AM (UTC) (see **Evidence/Atlas_Wes_3 - TCP + HTTP Stream 73.pcapng**).

3. Subsequently, Wes entered the critical part of the server, where the clients sensitive information was stored. The **77th TCP stream**, reveals that he navigated to the CONFIDENTIAL folder, where clients PCI are stored. The 11th of March, at 02:01:52 AM (UTC), Wes entered the CONFIDENTIAL/PCI directory and, from the captured HTTP request it can be seen in clear that the authentication token was still his (see **Evidence/Atlas_Wes_4 - PCI - TCP + HTTP Stream 77.pcapng**). A concerning consideration to be made at this point is that the server is hosted on a simple python http server (Server: SimpleHTTP/0.6 Python/3.10.6), with no security measures, leaving both the data and credentials visible in clear if the network traffic gets sniffed by a threat actor. Another crucial consideration is that the data visible in the HTTP response is the same as the one visible on the DarkWeb forum screenshot (see fig. 1). The PCI data on sale on shown in the sample matches the file names visible in the response. The screenshot was provided by the Security Manager.

4. Following the access to the confidential data, there is a sequence of automated scan requests visible in the **148th TCP stream** (see **Evidence/Atlas_Wes_5 - Automated Scan - TCP + HTTP Stream 148.pcapng**). 72 HTTP GET requests were made in a 20 seconds time span, between Atlas' IP address and the servers NAT address: 10.10.80.114 → 185.105.34.51 (`http://terrys-digital.uk`). However, the most important detail is that the timestamps have been tampered. Even though the time window of the provided network traffic capture began the 11th of March 2025 at 02:00:32 AM (UTC) and ended the 11th of March 2025 at 02:16:14 AM (UTC), the HTTP requests show that the timestamps begin with the first packet sent from the 14th of March 2025 00:10:47 AM (UTC). From the Wireshark capture the difference between when the first HTTP requests packet mentioned in the previous point is sent and the first packet of the automated scan results in just 60 seconds. Therefore, the time stamps do not match the time span visible in Wireshark and the timestamps of the HTTP requests.



(a) PCI data on sale



(b) Wireshark - HTTP response to Wes

Figure 1: DarkWeb filename match

5. The results mentioned in the previous point were then uploaded through a HTTP POST request, visible in the **185th TCP stream** (see **Evidence/Atlas_Wes_6 - ZAP Scan Report - TCP + HTTP Stream 185.pcapng**) From this report it can be seen that it is a scan made with the OWASP ZAP scanner tool. This artifact is named ZAP Scanning Report - Terry's Digital and it is a HTML vulnerability scan report generated by OWASP ZAP. The report was generated on the 11th of March 2025 at 02:03:08 AM (UTC) using ZAP v2.16.0. The scanned scope is `http://terrys-digital.uk` and it report 6 alerts in total, ranked by risk: 1 High, 2 Medium, 2 Low, and 1 Informational. Through this scan (see **Evidence/zapreport.pdf or Evidence/zap.txt**), several vulnerabilities have been signaled:

   - High Risk - Cloud Metadata Potentially Exposed, when doing a specific HTTP request, GET metadata/instance and using 169.254.169.254 as host header returned HTTP/1.1 200 OK.

     From the report: "*The Cloud Metadata Attack attempts to abuse a misconfigured NGINX server in order to access the instance metadata maintained by cloud service providers such as AWS, GCP and Azure. All of these providers provide metadata via an internal unroutable IP address '169.254.169.254' - this can be exposed by incorrectly configured NGINX servers and accessed by using this IP address in the Host header field. Based on the successful response status code cloud metadata may have been returned in the response. Check the response data to see if any cloud metadata has been returned. The meta data returned can include information that would allow an attacker to completely compromise the system.*" The returned metadata was the ACME Forensics web page. This means that there is abnormal content exposure;
   - Content Security Policy (CSP) missing , server version disclosed in the header of the HTTP request (Server: nginx/1.18.0 (Ubuntu));
   - X-Frame-Options or X-Content-Type-Options absent, the response has no protection against traffic sniffing or clickjacking.

   When doing the HTTP GET request for the main page, the server responded with the ransom-style defacement message, demanding the payment in ASCoin (`https://as-co.in`) to decrypt the data

of Terry's Digital. It is still visible when visiting the web page of the company on *http://terrys-digital.uk*

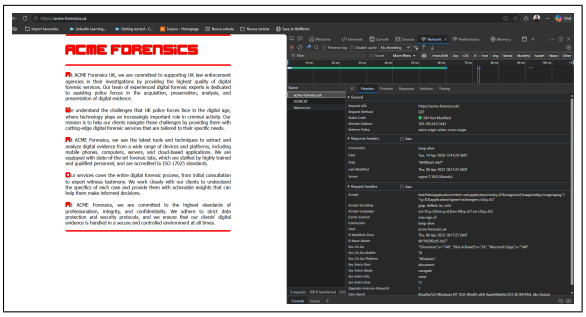
The scan was confirmed to be uploaded on 10.10.0.1:8080 via a POST request on the /UPLOADS directory. The server answered with HTTP/1.1 200 OK.

To investigate further POST requests, the following filters have been applied to Wireshark:

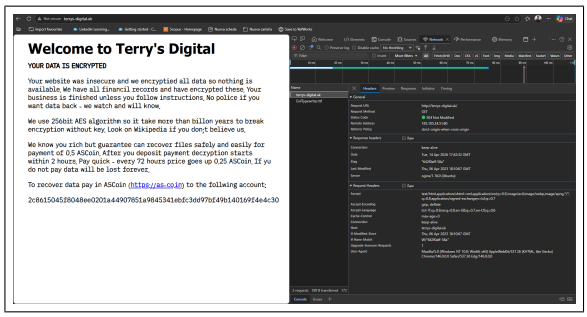
```
http.request.method == "POST" && http.host == "terrys-digital.uk"
# OR simply http.request.method == "POST"
```

6. The access to the UPLOADS folder with the username in clear text can be seen in the **188th TCP stream** and the uploads GET request to see the uploaded content is visible in the **811th TCP stream**, same IP address and same authorization token (see **Evidence/Atlas_Wes_7 - Clear Login - TCP + HTTP Stream 188.pcapng** and **Evidence/Atlas_Wes_8 - Upload Call - TCP + HTTP Stream 811.pcapng**).

7. In the previous request is also shown that there is a sslyze report also uploaded in the same directory. That upload POST request is visible in the **804th TCP stream** (see **Evidence/Atlas_Wes_16 - SSlyze Report - TCP + HTTP Stream 804.pcapng**). This report was uploaded shortly after the ZAP report on the 11th of March 2025 at 02:06:41 AM (UTC). The report was a plain text report generated after the automated scan of TLS/SSL configurations using SSLyze. The scope was *terrys-digital.uk:443* resolving to IP address *185.105.34.51*. The scan revealed critical certificate mismatch because the server, when called to serve *terrys-digital.uk* presented a 2048-bit RSA cert issued solely to *acme-forensics.uk*. In fact, when trying to connect to the resolved IP address on a browser it can be seen that it displays ACME Forensics web page. This suggests that the underlying NGINX server was hosting the ACME web page alongside the victim domain.



(a) ACME website displayed when reaching 185.105.34.51:443



(b) Terry's Digital website displayed, but same IP as ACME and different port 185.105.34.51:80

Figure 2: IP comparison on web console

After navigating the website it is clear that the scan also reached ACME's website pipeline. The ACME website has got TLS because it uses HTTPS on port 443 (see fig. 2a) while Terry's Digital website is reachable through HTTP on port 80 (see fig. 2b).

8. Wes's activity didn't stop here, from several different streams it was possible seeing that he navigated to suspect websites or inappropriate to visit while on the corporate internal network:

   - **TCP Stream 831** (see **Evidence/Atlas_Wes_9 - Love Honey Cam - TCP + HTTP Stream 831.pcapng**): Wes navigated to a website called Love Honey, a dating website, but the timestamp doesn't add up here as well. The HTTP GET request shows that the request was made on the 14th of March at 12:14:57 PM (UTC). The time window of the packet capture

is from 3 days earlier, so there is the possibility of a tampered timestamp. From the packet capture it can be noticed that this is also hosted on the same server (185.105.34.51). Digging even more, in the **827th** TCP stream it can be seen that Wes registered on the website (see **Evidence/Atlas_Wes_9.1 - Love Honey Cam Registration - TCP + HTTP Stream 827.pcapng**) as *wes-the-clicker*, using *ghostintheshell* as password (the same password that he uses to log into the critical server). However, the e-mail address that he uses is different. It is: wes-the-clicker@gmail.com

- **TCP Stream 890-905-926-934-935** (see **Evidence/Atlas_Wes_10 - Metasploit - TCP + HTTP Stream 890.pcapng, Evidence/Atlas_Wes_11 - Hydra_Git - TCP + HTTP + TLS Stream 905.pcapng, Evidence/Atlas_Wes_12 - BlackArch - TCP + TLS + HTTP Stream 926.pcapng, Evidence/Atlas_Wes_13 - Nmap - TCP + HTTP Stream 934.pcapng, Evidence/Atlas_Wes_14 - Zenmap - TCP + HTTP Stream 935.pcapng**): Network traffic towards suspicious websites has been extracted in the packet capture, including Metasploit, Hydra, BlackArch, Nmap and Zenmap. Also all of these packets have a timestamp different from the network traffic capture. They are all from the 14th of March 2025.

3.2.2 Kerry Cache - 10.10.50.88 - 02:48:59:44:52:41 - HYDRA:

1. Kerry was mentioned the first time from the e-mail exchange made between **B** and **D** where **B** states that she was gone AWOL and therefore he couldn't forward the network issue to her (see **Artifacts/RE Network Issues.eml**). The e-mail in which she was mentioned was sent the 11th of March 2025 at 02:18:05 AM (UTC). This suggests that in the time frame of the network capture subject of the investigation, **K** was not available/ out of reach. Nevertheless, from the **87th TCP stream**, it could be seen that someone with the username K3RRY-C4CH3 was connecting to a suspicious website (see **Evidence/Hydra_Kerry_1 - Dark Web - TCP Stream 87.pcapng**).

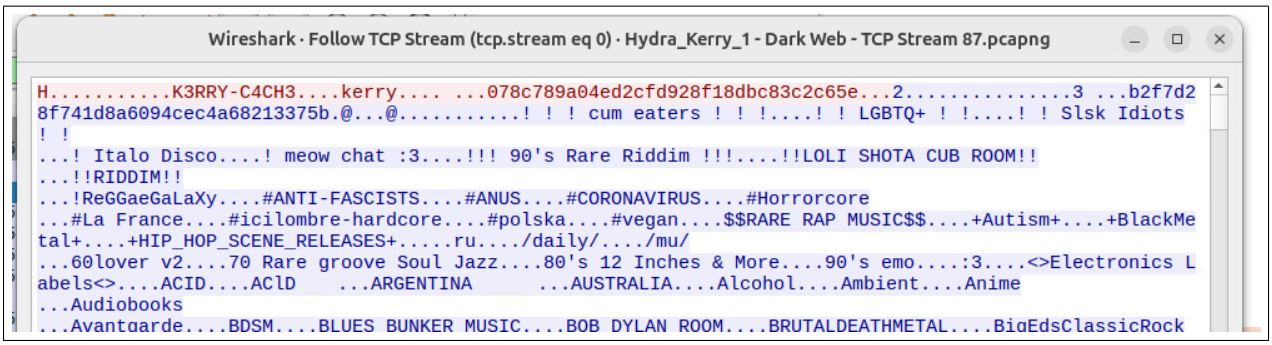


Figure 3: K3RRY Username on Suspicious Website

Following the TCP stream, it can be seen that it was a Dark web Website with all kind of things for sale. Scrolling at the end of the stream (from the 44th frame) a chat between someone named MYST3RION and K3RRY began (Destination IP: 208.70.170.59).

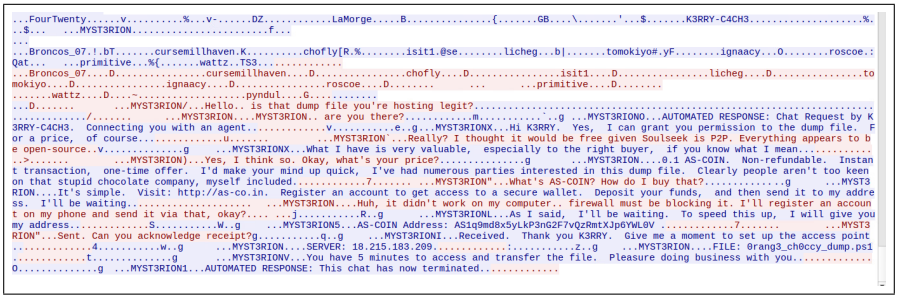


Figure 4: K3RRY Chat with MYST3RION

From the chat it can be seen that she wanted to buy a dump from MYST3RION. Then she makes a transaction in AS-Coin to purchase it, next MYST3RION provides to her an IP address to download the dump from an access point: *18.215.183.209*. The dump file is named 0rang3_ch0ccy_dump.ps1.

She mentions Soulseek in the chat, so clearly the activity registered in this specific packet capture is highly risky. Also, it can be noticed that MYST3RION says: "*I've had numerous parties interested in this dump file. Clearly people aren't too keen on that stupid chocolate company, myself included*". It refers to a chocolate company and this is an important to thing to take note of, since Terry's Digital is a confectionery brand.

This was the stream that showed clearly that she had 10.10.50.88 as IP address and that her name on the internal network was Hydra.

2. Kerry's connection to Soulseek can be noticed in the **88th TCP stream** (see **Evidence/Hydra_Kerry_2 - Soulseek - TCP Stream 88.pcapng**).

3. The **98th TCP stream** still shows Kerry navigating on the Dark Web. Her IP address is still the same, while the destination IP address changed to 83.84.172.29 (see **Evidence/Hydra_Kerry_3 - Darkweb - TCP Stream 98.pcapng**).

4. The last important thing that needs to be highlighted is the download of the dump named 0rang3_ch0ccy_dump.ps1 from the access point provided by MYST3RION. Kerry made an HTTP GET request for the dump on the provided IP address. When downloaded it can be seen that it is not a dump, instead it is a key logger (see **Evidence/Hydra_Kerry_4 - KeyLoggerDownload.pcapng** and **Evidence/0rang3_ch0ccy_dump.ps1**). The .ps1 extension was a clear hint about the fact that it was a Windows Powershell command file, rather than a dump file. Furthermore, once opened it connects the machine to the server (IP:18.215.183.209), logging the keystrokes in chunks of 50. The keylogger send the chunks through DNS queries, appending the suffix ".andrei-scottnikov.ru". From the packets in **Evidence/Hydra_Kerry_4 - KeyLoggerDownload.pcapng** it is visible that 39 DNS queries to the malicious server have been made. These queries contains some keystrokes, and presumably her credentials since she was typing *KERRY* and *TERRYSDIGITAL*. Some frames later she typed *ILOVEBUNNIES*.

   To catch this packet capture on the original Wireshark capture file, apply this filter:

   ```
   ip.addr == 18.215.183.209
   ```

   The IP addresses to which Kerry connected on the dark web have been checked on Virus Total and the last one, which also hosted the keylogger (18.215.183.209) was the only one flagged as a Criminal IP (see fig. 5). This query was made the 7th of April 2026 at 08:39:08 AM (UTC) on Virus Total's official website.

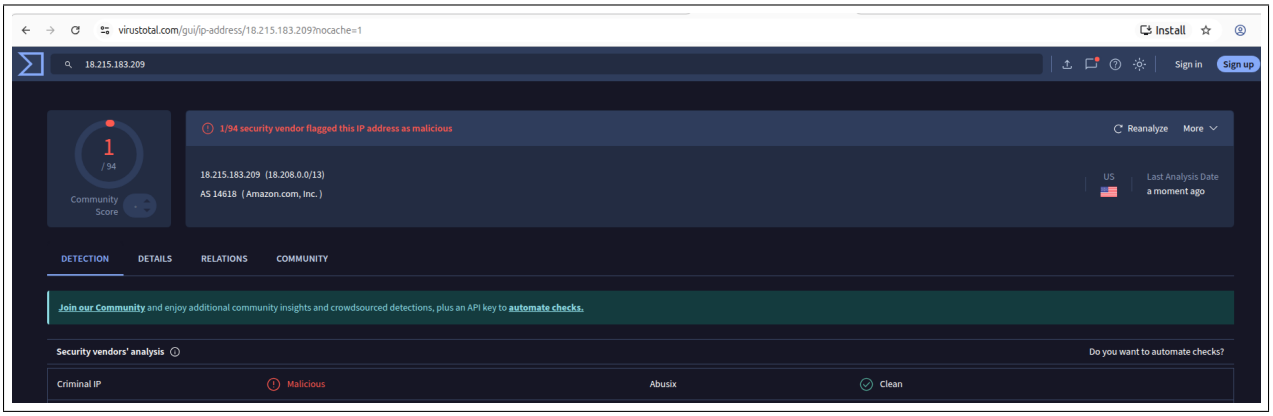


Figure 5: IP address flagged on Virus Total

3.2.3 Bob Browsalot - 10.10.30.212 - 02:4f:52:49:4f:4e - ORION:

1. Last but not least, there is Bob who can be noticed doing suspicious activities on the network. THe first think that could be seen were some crypto transactions on two separate TCP streams, **74 and 224** (see **Evidence/Orion_Bob_1 - TCP + Bitcoin Stream 74.pcapng** and **Evidence/Orion_Bob_4 - TCP + Bitcoin Stream 224.pcapng**).

2. The IP address 10.10.30.212 can be associated to Bob because in the **132nd TCP stream** it can be seen that he sends a POST request to Terry's Digital through a Python call, in which the username was Bob and the password was TerrysDigital123 (see **Evidence/Orion_Bob_2 - Auth - TCP + HTTP Stream 132.pcapng**)

3. Traffic from Bob's machine also revealed a suspect chat with ChatGPT 3.5 turbo. The communication happened through a python library. The alarming fact is that Bob vents to the LLM about issues he has during his current employment at Terry's Digital and was thinking about using sensitive information from the company to achieve enough resources to leave the job (see **Evidence/Orion_Bob_3 - ChatGPT - TCP + TLS + HTTP Stream 149.pcapng**). He wants to retire and go to the Maldives, therefore, since he states to the chatbot that he has a big crypto portfolio, it suggests him to avoid breaking the law and simply sell his crypto currency to have the money to then travel to the Maldives. The Bitcoin transactions mentioned above are transactions that he made to sell or exchange his cryptocurrency. The **TCP stream** on which this is visible is the **149th**.

4. Bob, following ChatGPT's advice registered on *https://members.visitmaldives.com*. Another proof that the *10.10.30.212* IP address is from the machine he is using is that the email he used in the registration process on the Maldives was bob@terrys-digital.uk (see **Evidence/Orion_Bob_5 - Maldives HTTP2.pcapng**). To catch this packet capture on the original Wireshark capture file, apply this filter:

```
http2.headers.authority == "members.visitmaldives.com"
```

Following there is a summative table of all the main hosts who got connected by the internal network.

Employee	**Internal Host/IP**	**Ext. IP**	**Purpose**
Wes Clickwell	ATLAS / 10.80.80.114	140.80.112.21	Reached for Hydra tool (GitHub)
Wes Clickwell	ATLAS / 10.80.80.114	136.243.110.152	Reached for BlackArch
Wes Clickwell	ATLAS / 10.80.80.114	108.138.217.58	Reached for Metasploit
Wes Clickwell	ATLAS / 10.80.80.114	50.116.1.184	Reached for Nmap
Kerry Cache	HYDRA / 10.10.30.212	83.84.172.29	Reached with K. Chache about pirated content
Kerry Cache	HYDRA / 10.10.50.88	208.70.170.59	Communicated with K. Chache for transaction for dump and later AS-Coin payment
Kerry Cache	HYDRA / 10.10.50.88	18.215.183.209	Server used to download the dump/keylogger
Bob Browsalot	ORION / 10.10.30.212	172.67.69.189	Maldives website
Bob Browsalot	ORION / 10.10.30.212	172.66.0.243	ChatGPT web hook IP address

Table 2: External hosts contacted by internal end-points

4 Results and Conclusion

Disclaimer: every time the network capture file was opened to view its contents (3e547-CAPTURE.pcap), whenever the work for that moment was finished and the file was closed, the hash of it was checked against the original one, to ensure its validity throughout the investigation.
Finally, it can be seen that the HTTP GET requests made after the frame 69340, visible in the 3e547-CAPTURE.pcap file (see **Files/3e547-CAPTURE.pcap**), show that the website had been encrypted. The GET requests were made from Wes's machine (IP addr: 10.10.80.114). Every file visible in the files mentioned in the section 3.2.1 now has the .locked extension. Now also the ransom text is visible on the main page. From the timestamp of the HTTP request, the first call was made on the 14th of March 2025 at 12:22:26 PM (UTC). Once again this timestamp either is tampered or the internal clock of the server is not in sync, given that the network capture was made the 11th of March 2025.
Each GET requested shows that the content of the server has been encrypted. Also two pictures have been downloaded from the UPLOAD folder, the first can be seen on the frame n. 70079 named 2d45cfafe7c9d7667ba4cdcb.locked and the other can be seen in the frame n. 70228 named f3401c2b419ca89ae04298a1.locked. Both of them downloaded from Wireshark could be opened and one was simply the picture of the company's headquarters, while the other was Terry with his family (see **Evidence/2d45cfafe7c9d7667ba4cdcb.locked** and **Evidence/f3401c2b419ca89ae04298a1.locked**). These pictures were analysed with Cyberchef, but nothing useful was found.
The only interesting fact is that in the ransom demand text the attacker asks to be paid in AS-Coin. It was the same payment method used by the person who provided Kerry the "dump", MYST3RION. However, the accounts number do not match.
The activity of Wes act as a potential insider threat, even though the person who allegedly thought of leaking the company's data was Bob while venting to ChatGPT. Kerry's action led her to downloading and executing a keylogger on her machine, putting at risk the internal network and potentially become the entry point for the attackers.
Nevertheless, the capture doesn't show explicit actions made for encrypting the website, instead it suddenly became encrypted. The HTTP request made from Wes's machine at 02:14:29 AM (UTC) on the 11th of March 2025, was the first that explicitly showed that the contents of the server were encrypted.
There are many aspects of the configuration and the actions of the employees that could have put the clients' PCI and PII data at risk:

- The web server wasn't secured enough: it was running on nginx, but the communication was not protected, the credentials of the employees could be seen in clear (e.g. Wes or Bob). All the traffic could be sniffed since most of it was simple HTTP traffic on port 80 in and out the server and all the contents could be read in clear and manipulated. The reports produced by Wes (ZAP and SSLyze) showed even more vulnerabilities of the server (see section 3.2.1) and since the traffic was in clear, a threat actor could also have sniffed the reports when he uploaded them, giving it all the tools to compromise the data.

- The employees actions were too dangerous. Kerry going in the dark web with a machine connected to the internal network of the company and ending up installing a key logger is a clear proof of the recklessness shown by them.

  Bob clearly was ready to leverage the company's sensitive data to earn enough money to leave his job and move to the Maldives. He also was caught doing Bitcoin transactions.

  Wes's action weren't too dangerous but some of the traffic he produced from his machine was towards offensive security tools websites that could potentially be a threat for the company if not handled with caution. There are no policies in place and, as Justin Case warned the company before the incident, the security analysts were overstepping secure boundaries.

To conclude, it can be said that it is not clear from the network capture what was the main chain of events that led to the compromise and data leak. However, the combination of the lack of policies and security measures opened the doors to malicious actors.

5 Expert Opinion: Legal Analysis

The following analysis is **just** an opinion, expressed providing an expert point of view and objective criteria. This is a speculation, based on the evidence found during the Forensic Investigation, of the *potential* liability and statutory violations resulting from the cyber incident that involved the British confectionery brand, Terry's Digital. The breach the company suffered, involved the exfiltration of PII and PCI data, along with the deployment of a ransomware that encrypted the material in the corporate network.

- **Computer Misuse Act 1990**
  - *s.1(1) CMA 1990* - Unauthorized access to computer material: the attacker committed an offence that falls under the CMA 1990 for gaining unauthorized access to the company's server;
  - *s.3(1) CMA 1990* - Unauthorised actions with intent to impair, or with recklessness as to impairing, operation of computer: the attacker deployed a ransomware in order to impair the company's operations, unless paid. The malicious actor encrypted all the information of the web server, making them inaccessible.
  - *The s.1(1) of the CMA 1990* could also be applied to the actions of the employees making them liable for unauthorized access to sensitive data. Wes Clickwell and Bob Browsalot might be guilty of accessing the CONFIDENTIAL/PCI directory without authorization. The server's answer to some data queries (e.g. the PCI information of a client) was "304 Not Modified", meaning that a prior access to that information already happened, even before the network capture. Additional factors that judges might consider are a motive to become an insider threat (e.g. Bob venting to the LLM about his job conditions) or the access to offensive security tools (e.g. Metasploit, Nmap).
- **UK GDPR 2018 and DPA 2018**
  - Breach of *Article 32(1) UK GDPR 2018* - failure to implement adequate technical and organisational measures in order reduce the risk increasing the level of security. The company failed to comply to the regulation significantly, given the forensic evidence about the methodology of handling sensitive data (e.g. data transmission over unencrypted channels). Specifically they failed under *Article 32(1)(b) UK GDPR 2018* that specifies the capability to ensure the "ongoing confidentiality, integrity, availability, of processing systems".
  - *Article 5(1)(f) UK GDPR 2018* - failure to process data in a secure manner in order to avoid unauthorized or unlawful data processing. Terry's Digital employees accessed sensitive data multiple time, making the company liable for this malpractice.
  - *s.170 DPA 2018* - If employees deliberately or recklessly consented to the data exfiltration process, being directly involved or not, they can be individually prosecuted for behaving unlawfully under the *s.170 of the DPA 2018*.

Employer liability for employee negligence: given the rogue behaviour of the employees, Terry's Digital cannot deflect easily regulatory fines (e.g. from the ICO) blaming the employees. The issue was deeper and an insider threat, even if not intentional, must be considered at a board level. The lack of policies and security measures explicitly shows the low effort put towards cyber and data security, also confirmed by the warnings of Mr. Justin Case, the company's CISO.
To conclude, it can be said that the gross negligence visible in the evidence and the systemic failure of the company's infrastructure, in terms of cybersecurity, aggravates the chance to be heavily fined for malpractice by the Information Commissioner's Office (ICO) for failing to comply to the regulations to which a data processor must attain. Furthermore, the employees that have been involved in the investigation demonstrated recklessness that breached basic security policies and potentially violated the CMA and DPA.

A CLI commands and hashes

Listing 1: Hashing

```
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools$ md5sum 3e547-CAPTURE.pcap
3e547-KEYS.log > checksum.md5
# files moved to files directory
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools$ cd files/
# files check
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/files$ md5sum -c checksum.md5
3e547-CAPTURE.pcap: OK
3e547-KEYS.log: OK

sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/files$ cat checksum.md5
e1293c30bc6c80f14eb92f7ce8f42f89  3e547-CAPTURE.pcap
5651928fcaa7168c003035dcf1bc55ba  3e547-KEYS.log

# backup folder hash and check
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/backup$ md5sum 3e547-CAPTURE.pcap
3e547-KEYS.log > checksum.md5
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/backup$ cat checksum.md5
e1293c30bc6c80f14eb92f7ce8f42f89  3e547-CAPTURE.pcap
5651928fcaa7168c003035dcf1bc55ba  3e547-KEYS.log
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/backup$ md5sum -c checksum.md5
3e547-CAPTURE.pcap: OK
3e547-KEYS.log: OK

# Artifacts hashing
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/Artifacts$ md5sum
DarkWeb_PCI-Terry_001.png DarkWeb_PCI-Terry_002.png
Networking\ Issues.eml RE\ Networking\ Issues.eml
Update\ on\ McVities\ SLAs.eml > checksum.md5
sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/Artifacts/Artifacts$ md5sum -c
checksum.md5
DarkWeb_PCI-Terry_001.png: OK
DarkWeb_PCI-Terry_002.png: OK
Networking Issues.eml: OK
RE Networking Issues.eml: OK
Update on McVities SLAs.eml: OK

sikri@vdi-scc-brw-003:~/h-drive/SCC.443/Tools/Artifacts$
cat checksum.md5
41b4974f62fdc3fb7eeff143654557e1  DarkWeb_PCI-Terry_001.png
33fe8c86a1a7f6f494125115576d4533  DarkWeb_PCI-Terry_002.png
17a757464a4db18609c102901190276e  Networking Issues.eml
63810c96886ed344188e2e113b562c3f  RE Networking Issues.eml
6041444505e7ea789412128d922309cf  Update on McVities SLAs.eml

# Evidence hash
sikri@vdi-scc-brw-047:~/h-drive/SCC.443/Tools/Evidence$ md5sum *.* > checksum.md5

sikri@vdi-scc-brw-047:~/h-drive/SCC.443/Tools/Evidence$ md5sum -c checksum.md5
0rang3_ch0ccy_dump.ps1: OK
2d45cfafe7c9d7667ba4cdcb.locked: OK
```

```
Atlas_Wes_10 - Metasploit - TCP + HTTP Stream 890.pcapng: OK
Atlas_Wes_11 - Hydra_Git - TCP + HTTP + TLS Stream 905.pcapng: OK
Atlas_Wes_12 - BlackArch - TCP + TLS + HTTP Stream 926.pcapng: OK
Atlas_Wes_13 - Nmap - TCP + HTTP Stream 934.pcapng: OK
Atlas_Wes_14 - Zenmap - TCP + HTTP Stream 935.pcapng: OK
Atlas_Wes_15 - Website call - Encypted - TCP + HTTP Stream 952.pcapng: OK
Atlas_Wes_16 - SSlyze Report  - TCP + HTTP Stream 804.pcapng: OK
Atlas_Wes_1 - TCP + HTTP Stream 44.pcapng: OK
Atlas_Wes_2 - TCP + HTTP Stream 64.pcapng: OK
Atlas_Wes_3 - TCP + HTTP Stream 73.pcapng: OK
Atlas_Wes_4 - PCI - TCP + HTTP Stream 77.pcapng: OK
Atlas_Wes_5 - Automated Scan- TCP + HTTP Stream 148.pcapng: OK
Atlas_Wes_6 - ZAP Scan Report - TCP + HTTP Stream 185.pcapng: OK
Atlas_Wes_7 - Clear Login - TCP + HTTP Stream 188.pcapng: OK
Atlas_Wes_8 - Upload Call - TCP + HTTP Stream 811.pcapng: OK
Atlas_Wes_9.1 - Love Honey Cam Registration - TCP + HTTP Stream 827.pcapng: OK
Atlas_Wes_9 - Love Honey Cam - TCP + HTTP Stream 831.pcapng: OK
f3401c2b419ca89ae04298a1.locked: OK
Hydra_Kerry_1 - Dark Web - TCP Stream 87.pcapng: OK
Hydra_Kerry_2 - Soulseek - TCP + HTTP Stream 88.pcapng: OK
Hydra_Kerry_3 - Darkweb - TCP Stream 98.pcapng: OK
Hydra_Kerry_4 - KeyLoggerDownload.pcapng: OK
Hydra_ Kerry - Soulseek Guide Download - qtversion.txt: OK
Orion_Bob_1 - TCP + Bitcoin Stream 74.pcapng: OK
Orion_Bob_2 - Auth - TCP + HTTP Stream 132.pcapng: OK
Orion_Bob_3 - ChatGPT - TCP + TLS + HTTP Stream 149.pcapng: OK
Orion_Bob_4 - Bitcoin - TCP + Bitcoin Stream 224.pcapng: OK
Orion_Bob_5 - Maldives  HTTP2.pcapng: OK
Virus Total Verification - Criminal IP.png: OK
zapreport.pdf: OK
zap.txt: OK

sikri@vdi-scc-brw-047:~/h-drive/SCC.443/Tools/Evidence$ cat checksum.md5
5dbd35762d536c749293c07facdcb975  0rang3_ch0ccy_dump.ps1
991c2a08eb76fc8d2d3b3ac98a120d17  2d45cfafe7c9d7667ba4cdcb.locked
83689a465256cbf683426aeaa56c363e  Atlas_Wes_10 - Metasploit -
TCP + HTTP Stream 890.pcapng

8cadb4efa34520d3670f33cc94ab6b9a  Atlas_Wes_11 - Hydra_Git -
TCP + HTTP + TLS Stream 905.pcapng

e8c38ffaf1ce842c4dea0e153c696ded  Atlas_Wes_12 - BlackArch -
TCP + TLS + HTTP Stream 926.pcapng

70eb5c34f49f51da6ef6b44aaf3271b8  Atlas_Wes_13 - Nmap -
TCP + HTTP Stream 934.pcapng

1ee48b426c02ee4ac2adfbf31fb76dbe  Atlas_Wes_14 - Zenmap -
TCP + HTTP Stream 935.pcapng

3074bd3886cec9aa7108dd65033e260d  Atlas_Wes_15 - Website call -
Encypted - TCP + HTTP Stream 952.pcapng
```

```
37d07cdde337f72b15c42baf048be0c0  Atlas_Wes_16 - SSlyze Report  -
TCP + HTTP Stream 804.pcapng

f3cc085c6f2f24c740064566111fec86  Atlas_Wes_1 - TCP + HTTP Stream 44.pcapng
d3c6c9d4f55c3ea847c7e12cb88e6f3c  Atlas_Wes_2 - TCP + HTTP Stream 64.pcapng
3f14df40cb227b3f11370255a628d647  Atlas_Wes_3 - TCP + HTTP Stream 73.pcapng
06dd65d2f801e9e50159bb3ba0213c30  Atlas_Wes_4 - PCI - TCP + HTTP Stream 77.pcapng
995e2c9f7d3042ae6403a02784c04e1a  Atlas_Wes_5 - Automated Scan-
TCP + HTTP Stream 148.pcapng

e4b6b7cdb7e07a164aa7be638922fdc6  Atlas_Wes_6 - ZAP Scan Report -
TCP + HTTP Stream 185.pcapng

d781ab0c1d6873f7772323c0e0f5ff4b  Atlas_Wes_7 - Clear Login -
TCP + HTTP Stream 188.pcapng

eedb519f881478cd462b1ec542cd25b4  Atlas_Wes_8 - Upload Call -
TCP + HTTP Stream 811.pcapng

ed3f9ddf8da34228519b828da372a524  Atlas_Wes_9.1 - Love Honey Cam Registration
- TCP + HTTP Stream 827.pcapng

56c6be28c276c341882228ba444e117c  Atlas_Wes_9 - Love Honey Cam -
TCP + HTTP Stream 831.pcapng

100064ac85819cce7a41e4a6b2414d34  f3401c2b419ca89ae04298a1.locked

39329765a67527e2c7e1966ee49fc384  Hydra_Kerry_1 - Dark Web -
TCP Stream 87.pcapng

bbe8a479c14430653a36ed1ff3153cb8  Hydra_Kerry_2 - Soulseek -
TCP + HTTP Stream 88.pcapng

1ef87a46a529ed1854211c91e8e3b52f  Hydra_Kerry_3 - Darkweb -
TCP Stream 98.pcapng

d91dafff265dbda8974efde88d79e516  Hydra_Kerry_4 - KeyLoggerDownload.pcapng
93ebcd2c907d258e9321fc2844b91351  Hydra_ Kerry - Soulseek Guide Download -
qtversion.txt

e48f6e4698791bbb5b34fc661e085b3f  Orion_Bob_1 - TCP + Bitcoin Stream 74.pcapng
aab39723298fcddee020c12bcfcb10d5  Orion_Bob_2 - Auth -
TCP + HTTP Stream 132.pcapng
220e08b01db77fa52dd45ab15b6af224  Orion_Bob_3 - ChatGPT -
TCP + TLS + HTTP Stream 149.pcapng
a96cecf0fbd1cb438b605dbc15eb17d4  Orion_Bob_4 - Bitcoin -
TCP + Bitcoin Stream 224.pcapng

8a2b00ae974b609aff018a7d4f15a0a6  Orion_Bob_5 - Maldives  HTTP2.pcapng
dc90d572338f688c266c4520457cbe91  Virus Total Verification - Criminal IP.png
b6e778ec37387607941d098236caa6ec  zapreport.pdf
5187e8928394b2699f295915906d498f  zap.txt
```

Commands:

```
md5sum file1.pdf, img1.png > checksum.md5
# to be quicker every file for each directory has been hashed in a single one with
    md5sum *.* > checksum.md5 - every directory has its own checksum.md5

# Hash checking, in the same directory where there is only the checksum and hashed
    files

md5sum -c checksum.md5

# Docker install and Cyberchef pull + launch

sudo snap install docker
sudo docker run -it -p 8080:80 ghcr.io/gchq/cyberchef:latest
```